Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. NIST SP 800-30 Rev. 1 is used to guide the risk analysis of the information system.

Purpose

Consider the following questions to help you write:

> The database server provides the data foundation necessary for the business to function; its security directly impacts company operations and brand reputation. If the server were to become non-operational, it would lead to business stagnation and operational chaos.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Competitor	*Modify/Delete Key Information*	*1*	*3*	*3*
Hacker	*Compromising servers to demand a ransom*	*2*	*3*	*6*
Customer	*Obtaining or learning of others' sensitive information for the purpose of selling it*	*3*	*3*	*9*

Approach

Databases are kept private, with access to information restricted to authorized users only. Databases are encrypted to ensure that, should malicious actors gain access to the data, they cannot use it directly. Furthermore, all database access is logged, providing evidence and a means to trace the origin of any incidents that may occur.

Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls, and multi-factor authentication to limit user privileges. Encryption of data in motion using TLS instead of SSL. IP allow-listing to corporate offices to prevent random users from the internet from connecting to the database. Apply the principle of least privilege to reduce the attack surface. Require MFA to verify users' identities. Employ a defense-in-depth approach to block and filter external attacks.